

SOC HANDS-ON WORKSHOP

SESIÓN 01

Onboarding + Exploración de datos

Despliega el lab · Caza amenazas con KQL · Primer incidente real

0

1

¿Qué veremos hoy?

00:00

Bienvenida y contexto del workshop

Qué es el Training Lab y qué haremos en 5 sesiones

00:15

¿Qué es un SOC y por qué Sentinel?

Panorama rápido — sin jerga innecesaria

00:30

Deploy del lab en Azure

ARM template · workspace SecShadow SOC · primeros datos

01:00

Ejercicio 01 · Advanced Hunting con KQL

Primera consulta sobre datos reales del ataque multi-etapa

01:30

Ejercicio 02 · Threat Intelligence con MDTI

IOCs, indicadores y cómo Sentinel los consume

01:50

Cierre y preview Sesión 02

Reflexión del grupo · preguntas · link registro

Entorno del lab

- ▶ 6 fuentes de datos simuladas
- ▶ 22 reglas de detección
- ▶ 10 tácticas MITRE ATT&CK
- ▶ 1 incidente unificado en XDR
- ▶ Aprox. 30 min para desplegar
- ▶ Costo: mínimo o cero

¿Qué es un SOC?

Security Operations Center — el equipo que defiende en tiempo real



Detectar

Identificar actividad maliciosa entre miles de eventos normales cada turno



Investigar

Entender qué pasó, quién, cuándo, desde dónde y hacia dónde



Contener

Aislar el problema antes de que se propague por la red



Recuperar

Devolver sistemas al estado normal y aprender del incidente

¿Por qué Microsoft Sentinel?

SIEM nativo en la nube · Escala automáticamente · Integrado con el ecosistema Microsoft · IA integrada con Security Copilot · Pago por consumo sin licencias fijas

"Un SOC efectivo debe entregar protección, detección, prevención y mitigación continua para todas las superficies de ataque. Sin XDR, el desafío central es demasiadas herramientas y demasiadas alertas."

El ataque que investigaremos

Un escenario multi-etapa realista · datos pre-grabados · sin necesidad de productos reales

01 Initial Access

Phishing bypassa
MailGuard365

02 Credential Access

Dump de credenciales
vía CrowdStrike

03 Defense Evasion

Manipulación MFA
en Okta

04 Lateral Movement

Port scan detectado
por Palo Alto

05 Privilege Escalation

IAM escalation
en AWS CloudTrail

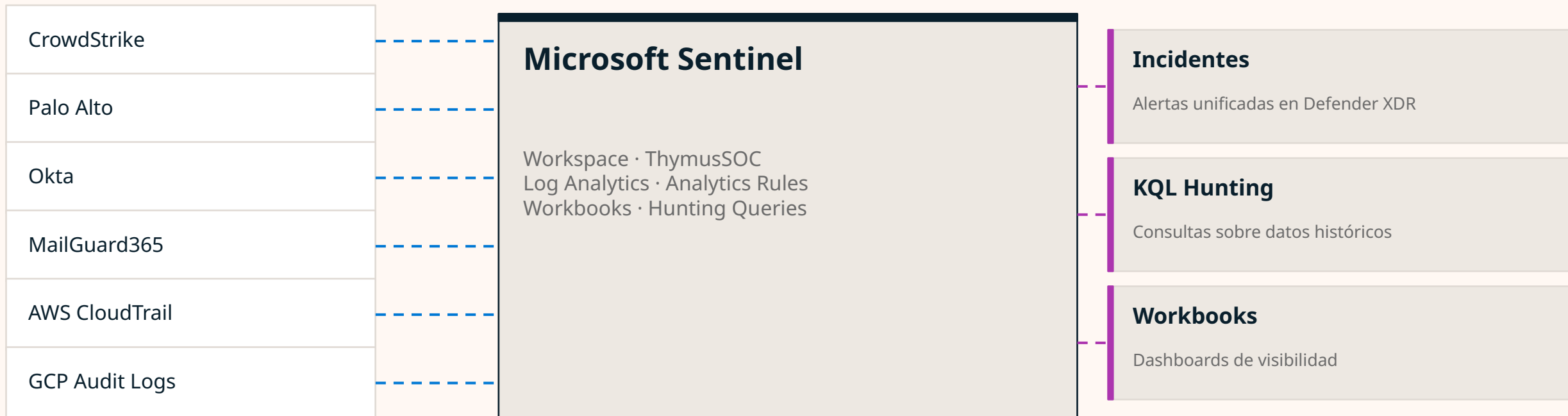
06 Persistence

Backdoor account
en GCP Audit Logs

⚠ Todos los datos son simulados — no necesitas CrowdStrike, Okta, Palo Alto, AWS ni GCP reales

¿Qué desplegamos en Azure?

ARM Template · Aprox. 30 minutos · costo mínimo o cero



Los datos viajan como CSV → Log Analytics Data Collector API → Custom Tables en Sentinel

Kill Chain mapeado al lab:

▶ Delivery → MailGuard365

▶ Exploitation → CrowdStrike

▶ C2 → Palo Alto

▶ Actions → AWS + GCP

Antes de desplegar

Lo que necesitas tener listo para el hands-on de hoy



Suscripción Azure activa

REQUERIDO

Con rol Owner o Contributor. Si no tienes, crea una de prueba en azure.microsoft.com/free



Microsoft Sentinel habilitado

REQUERIDO

O se habilita durante el deploy — el ARM template lo configura automáticamente



KQL básico

RECOMENDADO

Saber hacer un SELECT equivalente: search, where, project. No es bloqueante para esta sesión.



Defender XDR Portal

RECOMENDADO

Acceso a security.microsoft.com — para el incidente unificado del Ejercicio 01

💡 Sin suscripción Azure: crea una cuenta de prueba gratuita en azure.microsoft.com/free — \$200 USD de crédito por 30 días

EJ. 01

Advanced Hunting con KQL

Threat Intelligence · IOCs · Primera detección real

Objetivo

Ejecutar tu primera consulta KQL sobre los datos del lab y localizar evidencia del ataque inicial — el email de phishing que bypassó los filtros de MailGuard365.

Dónde lo harás

portal.azure.com
security.microsoft.com
→ Advanced Hunting

Primera query del lab:

```
// Buscar el email de phishing
EmailEvents_CL
| where TimeGenerated > ago(7d)
| where Subject_s has 'Invoice'
| project TimeGenerated, SenderIPv4_s,
  RecipientEmailAddress_s, Subject_s
| sort by TimeGenerated desc
```

Lo que verás al completar

1. Logs de MailGuard365 en la tabla custom EmailEvents_CL con el email malicioso
2. Campos clave: SenderIP, Subject, AttachmentName
3. Cómo cruzar ese IOC con otras tablas para rastrear al usuario comprometido

KQL en 3 minutos

Kusto Query Language — el lenguaje que usa Sentinel para consultar logs

SQL equivalente

```
SELECT *
```

```
WHERE campo = 'valor'
```

```
SELECT campo1, campo2
```

```
ORDER BY tiempo DESC
```

```
GROUP BY + COUNT
```

KQL

```
TableName
```

```
| where Campo == 'valor'
```

```
| project campo1, campo2
```

```
| sort by TimeGenerated desc
```

```
| summarize count() by Campo
```

Primera query del lab:

```
// Buscar el email de phishing
EmailEvents_CL
| where TimeGenerated > ago(7d)
| where Subject_s has 'Invoice'
| project TimeGenerated,
    SenderIPv4_s,
    RecipientEmailAddress_s,
    Subject_s,
    AttachmentNames_s
| sort by TimeGenerated desc
```

La sintaxis se lee de arriba hacia abajo como instrucciones en lenguaje natural

EJ. 02

Threat Intelligence con MDTI

Microsoft Defender Threat Intelligence · IOCs · Indicadores maliciosos

Objetivo

Conectar los IOCs del ataque (IPs, dominios, hashes) con la inteligencia de amenazas de Microsoft y entender cómo Sentinel los consume automáticamente en las reglas de detección.

Dónde lo harás

Microsoft Sentinel
→ Threat Intelligence
→ MDTI blade

¿Qué es Threat Intelligence?

Información sobre quién ataca, cómo ataca y con qué herramientas. Un IOC (Indicator of Compromise) es una IP, dominio, hash o email que sabemos que es malicioso.

Tipos de IOC que verás

IP maliciosa: 185.220.101.x — nodo Tor de C2

Dominio: update-service[.]xyz — phishing delivery

Hash SHA256: a3f...d9c — malware dropper

Email sender: invoice@legit-lookalike[.]com

"Los IOCs solos no atribuyen — son la capa más débil de la Pyramid of Pain. Lo que de verdad importa son los TTPs del actor. Cuando hoy conectas un IOC a MDTI, estás iniciando el proceso de atribución que veremos en detalle en la Sesión 02."

Pyramid of Pain

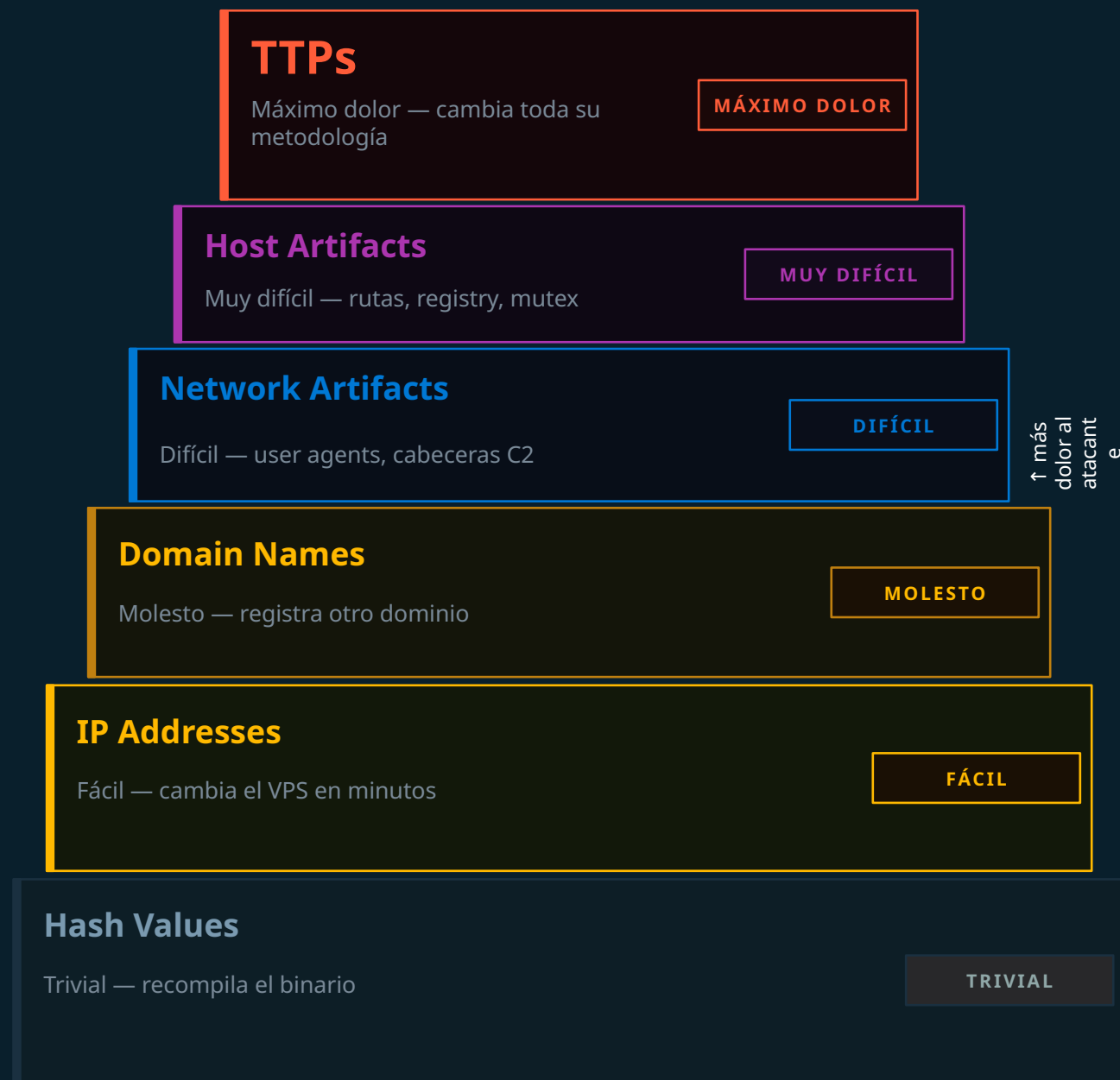
Cuanto más arriba detectás, más le duele al atacante cambiar.

💡 La clave operativa

Bloquear un hash lleva 30 segundos cambiar. Cambiar un TTP puede costar semanas y recursos. Tus reglas KQL en ThymusSOC operan en la cima.

ThymusSOC hoy

3.5M ThreatIntelIndicators (IPs/hashe) · 22 analytics rules en TTPs · CrowdStrike + Okta + MailGuard365



Pyramid of Pain aplicada al SOC

¿Por qué una regla KQL de comportamiento vale más que mil IOCs?

📦 Bajo valor

Hash Values

IP Addresses

El atacante los cambia en segundos o minutos. Bloquearlos es necesario pero no suficiente. Un antivirus puede hacerlo.

📦 En ThymusSOC

3.5M ThreatIntelIndicators de IPs y hashes bloqueados vía MDTI.

🕸 Valor medio

Domain Names

Network Artifacts

Requiere esfuerzo cambiar. El atacante necesita reconfigurar su infraestructura de C2 o reescribir partes del malware.

📦 En ThymusSOC

CommonSecurityLog — patrones de tráfico de Palo Alto que detectan comunicación con C2.

🕸 Alto valor — TTPs

Host Artifacts

TTPs

Cambiar un TTP significa cambiar la forma de operar. El atacante necesita reentrenarse, rediseñar su cadena de ataque y reorganizar su equipo.

📦 En ThymusSOC

Reglas de MFA abuse (T1621), port scan (T1046), inbox rule maliciosa (T1534).

Un solo incidente. Todo el ataque.

Cómo Sentinel y Defender XDR correlacionan las 22 alertas en un incidente cohesivo



Sin correlación, cada alerta es un ticket individual. Con Sentinel, el analista ve toda la historia de ataque en una sola vista y puede priorizar inteligentemente.

El camino de las 5 sesiones

Cada sesión construye sobre la anterior — un skill stack completo para analistas SOC

S01**HOY**

Onboarding + Exploración

- ▶ KQL básico
- ▶ Lab deploy
- ▶ Threat Intel

S02

Detección & MITRE ATT&CK

- ▶ MITRE mapping
- ▶ Automation
- ▶ Cross-platform

S03

Detection Engineering

- ▶ Rule tuning
- ▶ Watchlists
- ▶ FP reduction

S04

Operations + Data Lake

- ▶ Table tiers
- ▶ Data Lake
- ▶ Search Jobs

S05

AI + MCP + Federation

- ▶ AI agents
- ▶ MCP Server
- ▶ Federation

Cada sesión tiene su propio evento de registro — link en el comentario del post de LinkedIn

¿Qué lograste hoy?

Sesión 01 completada



Lab desplegado

Un SOC completo en Azure listo para operar



KQL operativo

Consultaste logs reales de un ataque multi-etapa



Threat Intel activa

IOCs conectados a Microsoft Defender TI



Incidente unificado

22 alertas → 1 historia de ataque cohesiva

Próxima sesión → S02: Detección & MITRE ATT&CK

Mapearás cada alerta al framework MITRE y automatizarás respuestas cross-platform entre CrowdStrike y MDE

Registro → meetup.com/msperu/events/314627391